

Board report

भारत डेटा प्राइवेट लिमिटेड

FY26 privacy and security review

Frameworks: India DPDPA (2023), ISO 27001 (2022)

Assessment period: 01 Apr 2026 to 30 Jun 2026 | Evidence cut-off: 15 Jul 2026

Report generated: 28 Sep 2026

Version v2 | Snapshot 5f2c9e1a

Released for reporting by Priya Sharma on 27 Sep 2026

This version is a draft until it is issued. Whether it was issued, who issued it and the SHA-256 of the issued file are recorded in the report version history.

Management summary

Basis of assessment

This document constitutes an evidence-based compliance gap assessment. It is not a formal compliance audit and does not constitute legal advice. Findings are based on documents submitted for review and information disclosed by the organization's representatives, and every conclusion was individually approved by a consultant. These conclusions reflect the evidence considered up to the evidence cut-off stated above.

Scope

- India DPDPA: 41 requirements in scope
- ISO 27001: 79 requirements in scope (Physical Controls excluded: single cloud-hosted office)

Limitations

This assessment does not include technical penetration testing, source code review, network security assessment, or any form of independent technical verification. Where the selected framework(s) include physical or environmental controls, findings on those controls are based on disclosed information and submitted documents, not on physical inspection or testing.

All findings reflect the information provided to the assessor at the time of the assessment. The assessor has not independently verified the accuracy or completeness of information provided. Material omissions or inaccuracies in disclosed information would affect the reliability of findings.

For requirements rated as Non-Compliant or Partially Compliant at a Critical or High risk level, independent verification by qualified legal counsel or a certified privacy professional (for INDIA DPDPA requirements), or by a qualified information security auditor (for ISO 27001), is strongly recommended before relying on those findings for regulatory submissions, board reporting, or contractual representations.

Most DPDPA 2023 obligations on Data Fiduciaries, and its penalty provisions, commence in mid-May 2027 (DPDP Rules 2025, G.S.R. 846(E)); findings against those obligations are a readiness assessment, not a determination of current non-compliance. Until then, obligations under the Information Technology Act, 2000, s.43A and the SPDI Rules, 2011 continue to apply and were not assessed.

Confidentiality

This report is prepared solely for the use of the named organization. It should not be shared with third parties without the organization's explicit consent. Golden Advisory and the named organization are the intended recipients of this report.

Scores and coverage

Framework	Headline	In scope	Compliant	Partial	Non-compliant	Insufficient evidence	Not applicable
India DPDPA	57% (Needs Significant Improvement); 5 requirement(s) insufficient evidence	41	10	21	5	5	0
ISO 27001	69% (Partially Compliant); 10 requirement(s) insufficient evidence	79	33	27	6	10	3

Scores are computed and reported independently for each framework; no score is combined across frameworks.

120 requirements assessed | 59 gaps identified (22 critical or high)

Top risks

1. Consent is collected through pre-ticked boxes

The sign-up journey and the marketing preference centre both pre-select consent. No record links a consent to the notice the user saw.

India DPDPA | CH2.CONSENT.1: Lawful basis for processing with free, specific, informed consent | Non-Compliant | Severity: critical | Priority: 1

privacy-policy.pdf v3, s.4.2, p.6 (SHA-256 a3f19c0e7b21)

Owner: Anita Rao (DPO) | Target: 30 Nov 2026

Action: Replace pre-ticked consent with an affirmative opt-in and log the notice version shown

2. No procedure to notify the Data Protection Board of a breach

The incident response plan covers containment only. It names no owner, timeline or template for notifying the Board or affected individuals.

India DPDPA | BN.NOTIFY.1: Breach notification to Data Protection Board | Non-Compliant | Severity: critical | Priority: 1
incident-response-plan.docx v2, s.5, p.3 (SHA-256 77c1d02e9a40)

Owner: Vikram Iyer (CISO) | Target: 31 Oct 2026

Action: Adopt a breach-notification runbook with owner, 72-hour timeline and regulator templates

3. Access rights are never reviewed

No periodic review of user access is evidenced for production systems. 14 leaver accounts were still active at the cut-off.

ISO 27001 | ISO.A5.18: Access rights | Non-Compliant | Severity: critical | Priority: 1
access-review-export.xlsx v1, Sheet 'Leavers', rows 2-15 (SHA-256 4be0d6a91c33)

Owner: Vikram Iyer (CISO) | Target: 15 Sep 2026

Action: Run quarterly access reviews for production and customer-data systems

4. No defined cadence for patching technical vulnerabilities

Scans run ad hoc; 23 critical CVEs older than 90 days were open on internet-facing hosts at the cut-off.

ISO 27001 | ISO.A8.8: Management of technical vulnerabilities | Non-Compliant | Severity: critical | Priority: 1
vuln-scan-summary.pdf v1, p.2 (SHA-256 e81a2c44f0d9)

Owner: Unassigned | Target: 15 Nov 2026

Action: Set patch SLAs (critical 15 days) and report monthly to the risk committee

5. Customer database access is not restricted by role

Encryption at rest is in place, but 41 engineers hold read access to the customer database with no role-based restriction.

India DPDPA | CH2.SECURITY.2: Encryption and access controls | Partially Compliant | Severity: high | Priority: 2

isms-manual.pdf v4, Annex B, p.22 (SHA-256 bb02f7a8d114)

Owner: Vikram Iyer (CISO) | Target: 15 Dec 2026

Action: Introduce role-based access to the customer database

6. Data Processor contracts lack data-protection clauses

Seven of nine processor contracts reviewed contain no security, breach-notice or deletion obligations.

India DPDPA | CH2.SECURITY.3: Data Processor contractual safeguards | Non-Compliant | Severity: high | Priority: 2

vendor-contracts-index.xlsx v2, rows 3-11 (SHA-256 0cd4e5f6a7b8)

Owner: Anita Rao (DPO) | Target: 28 Feb 2027

Action: Issue a data-processing addendum to all processors

7. Supplier security is not assessed before onboarding

A supplier questionnaire exists but is not used; no supplier risk tiering is recorded.

ISO 27001 | ISO.A5.19: Information security in supplier relationships | Partially Compliant | Severity: high | Priority: 2

Owner: Anita Rao (DPO) | Target: 28 Feb 2027

Action: Tier suppliers by data access and assess tier-1 suppliers annually

8. Customer data is retained indefinitely

The retention policy sets periods for HR records only; customer and KYC data have no retention period or deletion job.

India DPDPA | CH2.MINIMIZE.2: Data retention limited to purpose fulfilment | Partially Compliant | Severity: high | Priority: 2

data-retention-policy.pdf v1, s.3, p.2 (SHA-256 9d8e7f6a5b4c)

Owner: Ravi Menon (COO) | Target: 31 Mar 2027

Action: Define retention periods for customer and KYC data and automate deletion

9. Business continuity plan has never been tested

The BCP is approved but no test or exercise has been recorded since it was written in 2024.

ISO 27001 | ISO.A5.30: ICT readiness for business continuity | Partially Compliant | Severity: medium | Priority: 3

bcp-2024.pdf v1, whole (SHA-256 1a2b3c4d5e6f)

Owner: Ravi Menon (COO) | Target: 31 Mar 2027

Action: Test the BCP for the payments platform and record results

10. Grievance channel has no response timeline

Grievances are received through a shared mailbox with no tracking or response-time commitment.

India DPDPA | CH3.GRIEVANCE.1: Grievance redressal mechanism available | Partially Compliant | Severity: medium | Priority: 3

Owner: Unassigned | Target: No target date

Action: Publish a grievance form with tracking and a 30-day response commitment

Remediation roadmap

Actions recorded against approved findings, grouped by shared control: findings in different frameworks that cover the same control concern are listed together, so one remediation is tracked once. Groups are ordered by their earliest target date. Owners and dates are set by the consultant; nothing on this page is estimated.

Access control and privileged access

Fix once, closes 2 findings across ISO 27001 and India DPDPA

Action	Owner	Target date	Status	Finding
Run quarterly access reviews for production and customer-data systems	Vikram Iyer (CISO)	15 Sep 2026	Open	ISO 27001: ISO.A5.18 (Access rights are never reviewed)
Introduce role-based access to the customer database	Vikram Iyer (CISO)	15 Dec 2026	Open	India DPDPA: CH2.SECURITY.2 (Customer database access is not restricted by role)

Findings addressed: ISO 27001: ISO.A5.18 (Access rights are never reviewed); India DPDPA: CH2.SECURITY.2 (Customer database access is not restricted by role)

Incident and breach response

Addresses 1 finding in India DPDPA

Action	Owner	Target date	Status	Finding
Adopt a breach-notification runbook with owner, 72-hour timeline and regulator templates	Vikram Iyer (CISO)	31 Oct 2026	In progress	India DPDPA: BN.NOTIFY.1 (No procedure to notify the Data Protection Board of a breach)
Run a tabletop exercise covering Board and data-principal notification	Vikram Iyer (CISO)	31 Jan 2027	Open	India DPDPA: BN.NOTIFY.1 (No procedure to notify the Data Protection Board of a breach)

Findings addressed: India DPDPA: BN.NOTIFY.1 (No procedure to notify the Data Protection Board of a breach)

Vulnerability and patch management

Addresses 1 finding in ISO 27001

Action	Owner	Target date	Status	Finding
Set patch SLAs (critical 15 days) and report monthly to the risk committee	Unassigned	15 Nov 2026	Open	ISO 27001: ISO.A8.8 (No defined cadence for patching technical vulnerabilities)

Findings addressed: ISO 27001: ISO.A8.8 (No defined cadence for patching technical vulnerabilities)

Consent and notice

Addresses 1 finding in India DPDPA

Action	Owner	Target date	Status	Finding
Replace pre-ticked consent with an affirmative opt-in and log the notice version shown	Anita Rao (DPO)	30 Nov 2026	In progress	India DPDPA: CH2.CONSENT.1 (Consent is collected through pre-ticked boxes)

Findings addressed: India DPDPA: CH2.CONSENT.1 (Consent is collected through pre-ticked boxes)

Third-party and processor security

Fix once, closes 2 findings across ISO 27001 and India DPDPA

Action	Owner	Target date	Status	Finding
Issue a data-processing addendum to all processors	Anita Rao (DPO)	28 Feb 2027	Open	India DPDPA: CH2.SECURITY.3 (Data Processor contracts lack data-protection clauses)
Tier suppliers by data access and assess tier-1 suppliers annually	Anita Rao (DPO)	28 Feb 2027	Open	ISO 27001: ISO.A5.19 (Supplier security is not assessed before onboarding)

Findings addressed: India DPDPA: CH2.SECURITY.3 (Data Processor contracts lack data-protection clauses); ISO 27001: ISO.A5.19 (Supplier security is not assessed before onboarding)

Data retention and deletion

Addresses 1 finding in India DPDPA

Action	Owner	Target date	Status	Finding
Define retention periods for customer and KYC data and automate deletion	Ravi Menon (COO)	31 Mar 2027	Open	India DPDPA: CH2.MINIMIZE.2 (Customer data is retained indefinitely)

Findings addressed: India DPDPA: CH2.MINIMIZE.2 (Customer data is retained indefinitely)

Business continuity

Addresses 1 finding in ISO 27001

Action	Owner	Target date	Status	Finding
Test the BCP for the payments platform and record results	Ravi Menon (COO)	31 Mar 2027	Open	ISO 27001: ISO.A5.30 (Business continuity plan has never been tested)

Findings addressed: ISO 27001: ISO.A5.30 (Business continuity plan has never been tested)

Data-principal rights and grievances

Addresses 1 finding in India DPDPA

Action	Owner	Target date	Status	Finding
Publish a grievance form with tracking and a 30-day response commitment	Unassigned	No target date	Open	India DPDPA: CH3.GRIEVANCE.1 (Grievance channel has no response timeline)

Findings addressed: India DPDPA: CH3.GRIEVANCE.1 (Grievance channel has no response timeline)

What we could not assess

Insufficient evidence

- dpdpa: CH3.ACCESS.1 - Summary of personal data and processing activities
- dpdpa: CH4.SDF.2 - Independent Data Auditor appointed
- dpdpa: CM.RECORDS.1 - Consent records maintained
- dpdpa: BN.NOTIFY.2 - Breach notification to affected Data Principals
- dpdpa: BN.NOTIFY.4 - Breach register maintained
- iso27001: ISO.A5.1 - Policies for information security
- iso27001: ISO.A5.24 - Information security incident management planning and preparation
- iso27001: ISO.A5.33 - Protection of records
- iso27001: ISO.A5.36 - Compliance with policies, rules and standards
- iso27001: ISO.A6.3 - Information security awareness, education and training
- iso27001: ISO.A8.3 - Information access restriction
- iso27001: ISO.A8.7 - Protection against malware
- iso27001: ISO.A8.14 - Redundancy of information processing facilities
- iso27001: ISO.A8.25 - Secure development life cycle
- iso27001: ISO.A8.31 - Separation of development, test and production environments

Request for information

Issued version v2

- RFI-01: Consent records export for July 2026 (Required)
- RFI-02: Cross-border transfer register and destination list (Required)
- RFI-03: DPIA for the loan-underwriting model (Required)
- RFI-04: Last two backup-restore test reports (Recommended)

India DPDPA (2023)

Score: 57.0 (Needs Significant Improvement)

Domains

Domain	Score	Rating
Obligations of Data Fiduciary	49.2	Needs Significant Improvement
Rights of Data Principal	45.0	Needs Significant Improvement
Special Provisions	60.0	Partially Compliant
Consent Management (Detailed)	87.5	Compliant
Cross-Border Data Transfer	100.0	Compliant
Breach Notification	25.0	Non-Compliant

Gaps

Requirement	Outcome	Risk	Priority
BN.NOTIFY.1: Breach notification to Data Protection Board	Non-Compliant	critical	1
CH2.CONSENT.1: Lawful basis for processing with free, specific, informed consent	Non-Compliant	critical	1
CH2.CONSENT.3: Consent withdrawal mechanism	Partially Compliant	high	2
CH2.MINIMIZE.2: Data retention limited to purpose fulfilment	Partially Compliant	high	2
CH2.NOTICE.1: Notice accompanying the consent request	Partially Compliant	high	2
CH2.PURPOSE.1: Processing only for stated purpose	Partially Compliant	high	2
CH2.SECURITY.1: Reasonable security safeguards implemented	Partially Compliant	high	2
CH2.SECURITY.2: Encryption and access controls	Partially Compliant	high	2
CH2.SECURITY.3: Data Processor contractual safeguards	Non-Compliant	high	2
CH4.CHILD.1: No tracking or behavioural monitoring of children	Partially Compliant	high	2
CH4.CHILD.2: No processing detrimental to child's well-being	Partially Compliant	high	2
CH4.SDF.1: Data Protection Officer (DPO) appointed	Partially Compliant	high	2

Requirement	Outcome	Risk	Priority
CM.GRANULAR.2: No consent bundling with service access	Partially Compliant	high	2
BN.NOTIFY.3: Incident response plan documented	Partially Compliant	medium	3
CH2.MINIMIZE.1: Collection limited to what is necessary	Partially Compliant	medium	3
CH2.MINIMIZE.3: Retention schedule and deletion procedures	Non-Compliant	medium	3
CH2.NOTICE.2: Notice for previously collected data	Partially Compliant	medium	3
CH2.PURPOSE.2: Legitimate uses without consent properly identified	Partially Compliant	medium	3
CH3.CORRECT.2: Mechanism for erasure of personal data	Partially Compliant	medium	3
CH3.GRIEVANCE.1: Grievance redressal mechanism available	Partially Compliant	medium	3
CH3.GRIEVANCE.2: Timely response to grievances	Partially Compliant	medium	3
CH3.NOMINATE.1: Nomination mechanism for death or incapacity	Non-Compliant	medium	3
CH4.CHILD.3: Age verification mechanism	Partially Compliant	medium	3
CH4.SDF.3: Data Protection Impact Assessment (DPIA) conducted	Partially Compliant	medium	3
CH2.ACCURACY.1: Data accuracy ensured for decision-making and onward disclosure	Partially Compliant	low	4
CH2.NOTICE.3: Notice contains contact details of DPO or grievance officer	Partially Compliant	low	4

ISO 27001 (2022)

Score: 68.6 (Partially Compliant)

Domains

Domain	Score	Rating
Organizational Controls	65.3	Partially Compliant
People Controls	60.0	Partially Compliant
Physical Controls	Not applicable	Not applicable
Technological Controls	75.5	Partially Compliant

Gaps

Requirement	Outcome	Risk	Priority
ISO.A5.18: Access rights	Non-Compliant	critical	1
ISO.A8.8: Management of technical vulnerabilities	Non-Compliant	critical	1
ISO.A5.14: Information transfer	Non-Compliant	high	2
ISO.A5.15: Access control	Partially Compliant	high	2
ISO.A5.19: Information security in supplier relationships	Partially Compliant	high	2
ISO.A5.20: Addressing information security within supplier agreements	Non-Compliant	high	2
ISO.A5.26: Response to information security incidents	Partially Compliant	high	2
ISO.A5.34: Privacy and protection of personal information	Partially Compliant	high	2
ISO.A8.2: Privileged access rights	Partially Compliant	high	2
ISO.A5.21: Managing information security in the ICT supply chain	Partially Compliant	medium	3
ISO.A5.25: Assessment and decision on information security events	Partially Compliant	medium	3
ISO.A5.28: Collection of evidence	Non-Compliant	medium	3
ISO.A5.3: Segregation of duties	Partially Compliant	medium	3
ISO.A5.30: ICT readiness for business continuity	Partially Compliant	medium	3
ISO.A5.35: Independent review of information security	Partially Compliant	medium	3
ISO.A6.1: Screening	Partially Compliant	medium	3
ISO.A6.6: Confidentiality or non-disclosure agreements	Non-Compliant	medium	3
ISO.A6.7: Remote working	Partially Compliant	medium	3
ISO.A8.1: User endpoint devices	Partially Compliant	medium	3
ISO.A8.10: Information deletion	Partially Compliant	medium	3

Requirement	Outcome	Risk	Priority
ISO.A8.12: Data leakage prevention	Partially Compliant	medium	3
ISO.A8.15: Logging	Partially Compliant	medium	3
ISO.A8.22: Segregation of networks	Partially Compliant	medium	3
ISO.A8.27: Secure system architecture and engineering principles	Partially Compliant	medium	3
ISO.A8.29: Security testing in development and acceptance	Partially Compliant	medium	3
ISO.A8.32: Change management	Partially Compliant	medium	3
ISO.A5.10: Acceptable use of information and other associated assets	Partially Compliant	low	4
ISO.A5.11: Return of assets	Partially Compliant	low	4
ISO.A5.13: Labelling of information	Partially Compliant	low	4
ISO.A5.32: Intellectual property rights	Partially Compliant	low	4
ISO.A5.6: Contact with special interest groups	Partially Compliant	low	4
ISO.A6.4: Disciplinary process	Partially Compliant	low	4
ISO.A8.33: Test information	Partially Compliant	low	4

Prior-period comparison

Compared with the last issued board report for the previous assessment period in this engagement. The earlier report is read from its stored, hash-checked document and is never regenerated. Scores are compared within each framework only.

Compared with version v3 (snapshot c0ffee12) for the assessment period 01 Oct 2025 to 31 Dec 2025, evidence cut-off 15 Jan 2026, generated 02 Feb 2026.

Framework	Prior score	Current score	Change	Improved	Regressed	Changed	Newly assessed	No longer assessed
India DPDPA	41.0	57.0	+16.0 points	9	2	1	3	0
ISO 27001	58.5	68.6	+10.1 points	6	3	0	0	0

Gaps identified: 65 in the prior period, 59 in this period.

Requirement	Prior outcome	Current outcome	Change
India DPDPA: CH2.CONSENT.2 - Itemised consent for multiple purposes	Non-Compliant	Compliant	Improved
India DPDPA: CH2.CONSENT.4 - Consent Manager registration and interoperability	Partially Compliant	Compliant	Improved
India DPDPA: CH2.CONSENT.5 - Verifiable parental consent for children's data	Non-Compliant	Compliant	Improved
ISO 27001: ISO.A5.18 - Access rights	Partially Compliant	Non-Compliant	Regressed
ISO 27001: ISO.A8.8 - Management of technical vulnerabilities	Partially Compliant	Non-Compliant	Regressed

Sign-off

Prepared by: Priya Sharma

Reviewed by: Ravi Menon

Assessment period: 01 Apr 2026 to 30 Jun 2026

Evidence cut-off: 15 Jul 2026

Report generated: 28 Sep 2026

This version is a draft until it is issued. Whether it was issued, who issued it and the SHA-256 of the issued file are recorded in the report version history.

Names are recorded as entered by the consultant; they are not verified sign-ins.

Appendix A: Methodology

This assessment evaluates compliance against the following framework(s): India DPDPA, ISO 27001, across 120 in-scope requirements.

Basis of Assessment:

Each in-scope requirement receives one conclusion. The analysis engine reviews the submitted documents and questionnaire responses and proposes an outcome with cited evidence. A consultant reviews the evidence and individually approves, edits or rejects every proposal. Only individually approved conclusions appear in this report; no outcome, score or finding is produced by the AI on its own.

Outcome Definitions:

- Compliant: the requirement is met and supported by evidence
- Partially Compliant: the requirement is met in part
- Non-Compliant: the requirement is not met
- Insufficient Evidence: the evidence provided does not support a conclusion either way
- Not Applicable: the requirement does not apply within the assessed scope

Scoring Basis:

Scores are computed only from conclusions a consultant has individually approved. Each approved outcome counts as follows: Compliant 100 points, Partially Compliant 50 points, Non-Compliant 0 points. Not Applicable and Insufficient Evidence are excluded from the scoring denominator. Insufficient Evidence is not treated as Non-Compliant; the number of requirements with insufficient evidence is reported next to each framework score. Requirements excluded at scoping are not scored. A framework is scored only when every in-scope requirement has an approved conclusion. Section scores are the average of their requirement points; domain and framework scores are weighted averages using the published weights below.

Framework Structure and Weights:

- India DPDPA (2023): 41 requirements in 6 domains. Domain weights: Obligations of Data Fiduciary 30%, Rights of Data Principal 20%, Special Provisions 20%, Consent Management (Detailed) 10%, Cross-Border Data Transfer 10%, Breach Notification 10%.
 - ISO 27001 (2022): 93 requirements in 4 domains. Domain weights: Organizational Controls 35%, People Controls 15%, Physical Controls 15%, Technological Controls 35%.
- Requirements are referenced by clause or control identifier for each selected framework; requirement descriptions are summarised for assessment purposes and do not reproduce the source standard. Scores are computed and reported independently for each framework; no score is combined across frameworks.

Rating Thresholds:

- 80-100%: Compliant
- 60-79%: Partially Compliant
- 40-59%: Needs Significant Improvement
- 0-39%: Non-Compliant

Risk Classification:

Each gap carries the risk level (Critical, High, Medium, Low) approved by the consultant, reflecting regulatory exposure, potential penalties under INDIA DPDPA and impact on affected individuals (for INDIA DPDPA), and likely impact on the confidentiality, integrity and availability of information (for ISO

27001). Remediation priority on each gap is derived from its approved risk level.

Disclaimer:

This assessment provides guidance based on the information and evidence provided and is not legal advice. Consult qualified legal counsel for definitive compliance determinations under INDIA DPDPA. For ISO 27001, it is not a certification audit; certification decisions rest with an accredited certification body or qualified assessor.

Appendix B: Requirement register

Framework	Requirement	Outcome	Risk	Priority	Decision	Decided by	Decided on	Citation
dpdpa	CH2.CONSENT.1: Lawful basis for processing with free, specific, informed consent	Non-Compliant	critical	1	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, s.4.2, p.6
dpdpa	CH2.CONSENT.2: Itemised consent for multiple purposes	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.28
dpdpa	CH2.CONSENT.3: Consent withdrawal mechanism	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.18
dpdpa	CH2.CONSENT.4: Consent Manager registration and interoperability	Compliant	low	4	Edited	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.4
dpdpa	CH2.CONSENT.5: Verifiable parental consent for children's data	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.28
dpdpa	CH2.NOTICE.1: Notice accompanying the consent request	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.20
dpdpa	CH2.NOTICE.2: Notice for previously collected data	Partially Compliant	medium	3	Edited	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.3
dpdpa	CH2.NOTICE.3: Notice contains contact details of DPO or grievance officer	Partially Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.6
dpdpa	CH2.PURPOSE.1: Processing only for stated purpose	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.5
dpdpa	CH2.PURPOSE.2: Legitimate uses without consent properly identified	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.5

Framework	Requirement	Outcome	Risk	Priority	Decision	Decided by	Decided on	Citation
dpdpa	CH2.MINIMIZE.1: Collection limited to what is necessary	Partially Compliant	medium	3	Edited	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.21
dpdpa	CH2.MINIMIZE.2: Data retention limited to purpose fulfilment	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	data-retention-policy.pdf v1, s.3, p.2
dpdpa	CH2.MINIMIZE.3: Retention schedule and deletion procedures	Non-Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.16
dpdpa	CH2.ACCURACY.1: Data accuracy ensured for decision-making and onward disclosure	Partially Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.9
dpdpa	CH2.SECURITY.1: Reasonable security safeguards implemented	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.4
dpdpa	CH2.SECURITY.2: Encryption and access controls	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, Annex B, p.22
dpdpa	CH2.SECURITY.3: Data Processor contractual safeguards	Non-Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	vendor-contracts-index.xlsx v2, rows 3-11
dpdpa	CH3.ACCESS.1: Summary of personal data and processing activities	Insufficient Evidence	high	2	Approved	Priya Sharma	24 Sep 2026	No supporting citation
dpdpa	CH3.CORRECT.1: Mechanism for correction and completion of data	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.18
dpdpa	CH3.CORRECT.2: Mechanism for erasure of personal data	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.17
dpdpa	CH3.GRIEVANCE.1: Grievance redressal mechanism available	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.26

Framework	Requirement	Outcome	Risk	Priority	Decision	Decided by	Decided on	Citation
dpdpa	CH3.GRIEVANCE.2: Timely response to grievances	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.12
dpdpa	CH3.NOMINATE.1: Nomination mechanism for death or incapacity	Non-Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.4
dpdpa	CH4.CHILD.1: No tracking or behavioural monitoring of children	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.24
dpdpa	CH4.CHILD.2: No processing detrimental to child's well-being	Partially Compliant	high	2	Edited	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.22
dpdpa	CH4.CHILD.3: Age verification mechanism	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.11
dpdpa	CH4.SDF.1: Data Protection Officer (DPO) appointed	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.2
dpdpa	CH4.SDF.2: Independent Data Auditor appointed	Insufficient Evidence	high	2	Approved	Priya Sharma	24 Sep 2026	No supporting citation
dpdpa	CH4.SDF.3: Data Protection Impact Assessment (DPIA) conducted	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.26
dpdpa	CH4.SDF.4: Periodic audit completed	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.14
dpdpa	CM.RECORDS.1: Consent records maintained	Insufficient Evidence	high	2	Approved	Priya Sharma	24 Sep 2026	No supporting citation
dpdpa	CM.RECORDS.2: Fresh consent for a new or changed purpose	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.30
dpdpa	CM.GRANULAR.1: Granular consent options available	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.24
dpdpa	CM.GRANULAR.2: No consent bundling with service access	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.9

Framework	Requirement	Outcome	Risk	Priority	Decision	Decided by	Decided on	Citation
dpdpa	CB.TRANSFER.1: Data transfers only to non-restricted jurisdictions	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.23
dpdpa	CB.TRANSFER.2: Transfers comply with s.16 restrictions and stricter sectoral law	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.10
dpdpa	CB.TRANSFER.3: Data localisation where required	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.21
dpdpa	BN.NOTIFY.1: Breach notification to Data Protection Board	Non-Compliant	critical	1	Approved	Priya Sharma	24 Sep 2026	incident-response-plan.docx v2, s.5, p.3
dpdpa	BN.NOTIFY.2: Breach notification to affected Data Principals	Insufficient Evidence	critical	1	Approved	Priya Sharma	24 Sep 2026	No supporting citation
dpdpa	BN.NOTIFY.3: Incident response plan documented	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.16
dpdpa	BN.NOTIFY.4: Breach register maintained	Insufficient Evidence	medium	3	Approved	Priya Sharma	24 Sep 2026	No supporting citation
iso27001	ISO.A5.1: Policies for information security	Insufficient Evidence	critical	1	Approved	Priya Sharma	24 Sep 2026	No supporting citation
iso27001	ISO.A5.2: Information security roles and responsibilities	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.17
iso27001	ISO.A5.3: Segregation of duties	Partially Compliant	medium	3	Edited	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.8
iso27001	ISO.A5.4: Management responsibilities	Compliant	low	4	Edited	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.5
iso27001	ISO.A5.5: Contact with authorities	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.13
iso27001	ISO.A5.6: Contact with special interest groups	Partially Compliant	low	4	Edited	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.21

Framework	Requirement	Outcome	Risk	Priority	Decision	Decided by	Decided on	Citation
iso27001	ISO.A5.7: Threat intelligence	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.21
iso27001	ISO.A5.8: Information security in project management	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.16
iso27001	ISO.A5.9: Inventory of information and other associated assets	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.5
iso27001	ISO.A5.10: Acceptable use of information and other associated assets	Partially Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.28
iso27001	ISO.A5.11: Return of assets	Partially Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.18
iso27001	ISO.A5.12: Classification of information	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.26
iso27001	ISO.A5.13: Labelling of information	Partially Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.24
iso27001	ISO.A5.14: Information transfer	Non-Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.13
iso27001	ISO.A5.15: Access control	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.22
iso27001	ISO.A5.16: Identity management	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.27
iso27001	ISO.A5.17: Authentication information	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.8
iso27001	ISO.A5.18: Access rights	Non-Compliant	critical	1	Approved	Priya Sharma	24 Sep 2026	access-review-export.xlsx v1, Sheet 'Leavers', rows 2-15
iso27001	ISO.A5.19: Information security in supplier relationships	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.2

Framework	Requirement	Outcome	Risk	Priority	Decision	Decided by	Decided on	Citation
iso27001	ISO.A5.20: Addressing information security within supplier agreements	Non-Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.24
iso27001	ISO.A5.21: Managing information security in the ICT supply chain	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.13
iso27001	ISO.A5.22: Monitoring, review and change management of supplier services	Compliant	low	4	Edited	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.8
iso27001	ISO.A5.23: Information security for use of cloud services	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.17
iso27001	ISO.A5.24: Information security incident management planning and preparation	Insufficient Evidence	critical	1	Approved	Priya Sharma	24 Sep 2026	No supporting citation
iso27001	ISO.A5.25: Assessment and decision on information security events	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.14
iso27001	ISO.A5.26: Response to information security incidents	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.30
iso27001	ISO.A5.27: Learning from information security incidents	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.4
iso27001	ISO.A5.28: Collection of evidence	Non-Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.16
iso27001	ISO.A5.29: Information security during disruption	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.7
iso27001	ISO.A5.30: ICT readiness for business continuity	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	bcp-2024.pdf v1, whole

Framework	Requirement	Outcome	Risk	Priority	Decision	Decided by	Decided on	Citation
iso27001	ISO.A5.31: Legal, statutory, regulatory and contractual requirements	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.27
iso27001	ISO.A5.32: Intellectual property rights	Partially Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.23
iso27001	ISO.A5.33: Protection of records	Insufficient Evidence	high	2	Approved	Priya Sharma	24 Sep 2026	No supporting citation
iso27001	ISO.A5.34: Privacy and protection of personal information	Partially Compliant	high	2	Edited	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.18
iso27001	ISO.A5.35: Independent review of information security	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.28
iso27001	ISO.A5.36: Compliance with policies, rules and standards	Insufficient Evidence	medium	3	Edited	Priya Sharma	24 Sep 2026	No supporting citation
iso27001	ISO.A5.37: Documented operating procedures	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.10
iso27001	ISO.A6.1: Screening	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.25
iso27001	ISO.A6.2: Terms and conditions of employment	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.28
iso27001	ISO.A6.3: Information security awareness, education and training	Insufficient Evidence	critical	1	Approved	Priya Sharma	24 Sep 2026	No supporting citation
iso27001	ISO.A6.4: Disciplinary process	Partially Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.29
iso27001	ISO.A6.5: Responsibilities after termination or change of employment	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.26

Framework	Requirement	Outcome	Risk	Priority	Decision	Decided by	Decided on	Citation
iso27001	ISO.A6.6: Confidentiality or non-disclosure agreements	Non-Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.21
iso27001	ISO.A6.7: Remote working	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.23
iso27001	ISO.A6.8: Information security event reporting	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.30
iso27001	ISO.A8.1: User endpoint devices	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.3
iso27001	ISO.A8.2: Privileged access rights	Partially Compliant	high	2	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.26
iso27001	ISO.A8.3: Information access restriction	Insufficient Evidence	high	2	Edited	Priya Sharma	24 Sep 2026	No supporting citation
iso27001	ISO.A8.4: Access to source code	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.24
iso27001	ISO.A8.5: Secure authentication	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.18
iso27001	ISO.A8.6: Capacity management	Not Applicable	medium	3	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.19
iso27001	ISO.A8.7: Protection against malware	Insufficient Evidence	critical	1	Approved	Priya Sharma	24 Sep 2026	No supporting citation
iso27001	ISO.A8.8: Management of technical vulnerabilities	Non-Compliant	critical	1	Approved	Priya Sharma	24 Sep 2026	vuln-scan-summary.pdf v1, p.2
iso27001	ISO.A8.9: Configuration management	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.4
iso27001	ISO.A8.10: Information deletion	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.23
iso27001	ISO.A8.11: Data masking	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.24

Framework	Requirement	Outcome	Risk	Priority	Decision	Decided by	Decided on	Citation
iso27001	ISO.A8.12: Data leakage prevention	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.30
iso27001	ISO.A8.13: Information backup	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.14
iso27001	ISO.A8.14: Redundancy of information processing facilities	Insufficient Evidence	medium	3	Approved	Priya Sharma	24 Sep 2026	No supporting citation
iso27001	ISO.A8.15: Logging	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.18
iso27001	ISO.A8.16: Monitoring activities	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.12
iso27001	ISO.A8.17: Clock synchronization	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.19
iso27001	ISO.A8.18: Use of privileged utility programs	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.12
iso27001	ISO.A8.19: Installation of software on operational systems	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.5
iso27001	ISO.A8.20: Networks security	Not Applicable	critical	1	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.4
iso27001	ISO.A8.21: Security of network services	Compliant	low	4	Edited	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.10
iso27001	ISO.A8.22: Segregation of networks	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.14
iso27001	ISO.A8.23: Web filtering	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.24
iso27001	ISO.A8.24: Use of cryptography	Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.15
iso27001	ISO.A8.25: Secure development life cycle	Insufficient Evidence	high	2	Approved	Priya Sharma	24 Sep 2026	No supporting citation

Framework	Requirement	Outcome	Risk	Priority	Decision	Decided by	Decided on	Citation
iso27001	ISO.A8.26: Application security requirements	Compliant	low	4	Edited	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.4
iso27001	ISO.A8.27: Secure system architecture and engineering principles	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	questionnaire-response.pdf v1, p.29
iso27001	ISO.A8.28: Secure coding	Compliant	low	4	Edited	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.10
iso27001	ISO.A8.29: Security testing in development and acceptance	Partially Compliant	medium	3	Edited	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.5
iso27001	ISO.A8.30: Outsourced development	Not Applicable	medium	3	Approved	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.8
iso27001	ISO.A8.31: Separation of development, test and production environments	Insufficient Evidence	high	2	Approved	Priya Sharma	24 Sep 2026	No supporting citation
iso27001	ISO.A8.32: Change management	Partially Compliant	medium	3	Approved	Priya Sharma	24 Sep 2026	access-control-policy.pdf v2, p.18
iso27001	ISO.A8.33: Test information	Partially Compliant	low	4	Approved	Priya Sharma	24 Sep 2026	isms-manual.pdf v4, p.10
iso27001	ISO.A8.34: Protection of information systems during audit testing	Compliant	low	4	Edited	Priya Sharma	24 Sep 2026	privacy-policy.pdf v3, p.18

Appendix C: Evidence register

File	Version	Added	Status	SHA-256	Cited
access-control-policy.pdf	v2	01 Jul 2026	active	1de5f3770ef3	Yes
access-review-export.xlsx	v1	02 Jul 2026	active	364c9e4532f5	Yes
bcp-2024.pdf	v1	03 Jul 2026	active	a1b0f1123755	Yes
data-retention-policy.pdf	v1	04 Jul 2026	active	2cbb1cc40c0f	Yes
incident-response-plan.docx	v2	05 Jul 2026	active	f3e29123e1bc	Yes
isms-manual.pdf	v4	06 Jul 2026	active	8d660260deff	Yes
privacy-policy.pdf	v3	07 Jul 2026	active	a190766d8cf1	Yes
questionnaire-response.pdf	v1	08 Jul 2026	active	e1868fedc2eb	Yes
vendor-contracts-index.xlsx	v2	09 Jul 2026	active	e1fbefe47ef9	Yes
vuln-scan-summary.pdf	v1	01 Jul 2026	active	f948886d759e	Yes
board-minutes-q1.pdf	v1	02 Jul 2026	active	3d89df41cdb2	No

Appendix D: Statement of Applicability

Every Annex A control of ISO 27001:2022, with its applicability, implementation status and justification. Applicability and implementation status are derived from the consultant-approved conclusion for each control; justifications are recorded by the consultant.

This statement records the assessor's view at the evidence cut-off. It does not replace the organization's own Statement of Applicability.

14 Annex A control(s) were outside the scope of this assessment. Their applicability has not been determined; the organization must decide it before relying on this statement.

90 control(s) have no recorded justification.

Control	Theme	Applicability	Implementation	Justification
Annex A.5.1 Policies for information security	Organizational Controls	Applicable	Not determined	Justification not recorded
Annex A.5.2 Information security roles and responsibilities	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.3 Segregation of duties	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.4 Management responsibilities	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.5 Contact with authorities	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.6 Contact with special interest groups	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.7 Threat intelligence	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.8 Information security in project management	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.9 Inventory of information and other associated assets	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.10 Acceptable use of information and other associated assets	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.11 Return of assets	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.12 Classification of information	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.13 Labelling of information	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.14 Information transfer	Organizational Controls	Applicable	Not implemented	Justification not recorded
Annex A.5.15 Access control	Organizational Controls	Applicable	Partially implemented	Justification not recorded

Control	Theme	Applicability	Implementation	Justification
Annex A.5.16 Identity management	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.17 Authentication information	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.18 Access rights	Organizational Controls	Applicable	Not implemented	Justification not recorded
Annex A.5.19 Information security in supplier relationships	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.20 Addressing information security within supplier agreements	Organizational Controls	Applicable	Not implemented	Justification not recorded
Annex A.5.21 Managing information security in the ICT supply chain	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.22 Monitoring, review and change management of supplier services	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.23 Information security for use of cloud services	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.24 Information security incident management planning and preparation	Organizational Controls	Applicable	Not determined	Justification not recorded
Annex A.5.25 Assessment and decision on information security events	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.26 Response to information security incidents	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.27 Learning from information security incidents	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.28 Collection of evidence	Organizational Controls	Applicable	Not implemented	Justification not recorded
Annex A.5.29 Information security during disruption	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.30 ICT readiness for business continuity	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.31 Legal, statutory, regulatory and contractual requirements	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.5.32 Intellectual property rights	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.33 Protection of records	Organizational Controls	Applicable	Not determined	Justification not recorded

Control	Theme	Applicability	Implementation	Justification
Annex A.5.34 Privacy and protection of personal information	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.35 Independent review of information security	Organizational Controls	Applicable	Partially implemented	Justification not recorded
Annex A.5.36 Compliance with policies, rules and standards	Organizational Controls	Applicable	Not determined	Justification not recorded
Annex A.5.37 Documented operating procedures	Organizational Controls	Applicable	Implemented	Justification not recorded
Annex A.6.1 Screening	People Controls	Applicable	Partially implemented	Justification not recorded
Annex A.6.2 Terms and conditions of employment	People Controls	Applicable	Implemented	Justification not recorded
Annex A.6.3 Information security awareness, education and training	People Controls	Applicable	Not determined	Justification not recorded
Annex A.6.4 Disciplinary process	People Controls	Applicable	Partially implemented	Justification not recorded
Annex A.6.5 Responsibilities after termination or change of employment	People Controls	Applicable	Implemented	Justification not recorded
Annex A.6.6 Confidentiality or non-disclosure agreements	People Controls	Applicable	Not implemented	Justification not recorded
Annex A.6.7 Remote working	People Controls	Applicable	Partially implemented	Justification not recorded
Annex A.6.8 Information security event reporting	People Controls	Applicable	Implemented	Justification not recorded
Annex A.7.1 Physical security perimeters	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.2 Physical entry	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.3 Securing offices, rooms and facilities	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.4 Physical security monitoring	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.5 Protecting against physical and environmental threats	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.6 Working in secure areas	Physical Controls	Not determined	Not assessed	Justification not recorded

Control	Theme	Applicability	Implementation	Justification
Annex A.7.7 Clear desk and clear screen	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.8 Equipment siting and protection	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.9 Security of assets off-premises	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.10 Storage media	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.11 Supporting utilities	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.12 Cabling security	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.13 Equipment maintenance	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.7.14 Secure disposal or re-use of equipment	Physical Controls	Not determined	Not assessed	Justification not recorded
Annex A.8.1 User endpoint devices	Technological Controls	Applicable	Partially implemented	Justification not recorded
Annex A.8.2 Privileged access rights	Technological Controls	Applicable	Partially implemented	Justification not recorded
Annex A.8.3 Information access restriction	Technological Controls	Applicable	Not determined	Justification not recorded
Annex A.8.4 Access to source code	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.5 Secure authentication	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.6 Capacity management	Technological Controls	Excluded	Not applicable	Not relevant to the cloud-only operating model.
Annex A.8.7 Protection against malware	Technological Controls	Applicable	Not determined	Justification not recorded
Annex A.8.8 Management of technical vulnerabilities	Technological Controls	Applicable	Not implemented	Justification not recorded
Annex A.8.9 Configuration management	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.10 Information deletion	Technological Controls	Applicable	Partially implemented	Justification not recorded
Annex A.8.11 Data masking	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.12 Data leakage prevention	Technological Controls	Applicable	Partially implemented	Justification not recorded

Control	Theme	Applicability	Implementation	Justification
Annex A.8.13 Information backup	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.14 Redundancy of information processing facilities	Technological Controls	Applicable	Not determined	Justification not recorded
Annex A.8.15 Logging	Technological Controls	Applicable	Partially implemented	Justification not recorded
Annex A.8.16 Monitoring activities	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.17 Clock synchronization	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.18 Use of privileged utility programs	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.19 Installation of software on operational systems	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.20 Networks security	Technological Controls	Excluded	Not applicable	Not relevant to the cloud-only operating model.
Annex A.8.21 Security of network services	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.22 Segregation of networks	Technological Controls	Applicable	Partially implemented	Justification not recorded
Annex A.8.23 Web filtering	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.24 Use of cryptography	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.25 Secure development life cycle	Technological Controls	Applicable	Not determined	Justification not recorded
Annex A.8.26 Application security requirements	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.27 Secure system architecture and engineering principles	Technological Controls	Applicable	Partially implemented	Justification not recorded
Annex A.8.28 Secure coding	Technological Controls	Applicable	Implemented	Justification not recorded
Annex A.8.29 Security testing in development and acceptance	Technological Controls	Applicable	Partially implemented	Justification not recorded
Annex A.8.30 Outsourced development	Technological Controls	Excluded	Not applicable	No on-premises development; all development is outsourced under contract.

Control	Theme	Applicability	Implementation	Justification
Annex A.8.31 Separation of development, test and production environments	Technological Controls	Applicable	Not determined	Justification not recorded
Annex A.8.32 Change management	Technological Controls	Applicable	Partially implemented	Justification not recorded
Annex A.8.33 Test information	Technological Controls	Applicable	Partially implemented	Justification not recorded
Annex A.8.34 Protection of information systems during audit testing	Technological Controls	Applicable	Implemented	Justification not recorded